

Hollow House Institute

Sector-Specific AI Governance Kits

Why One Size Fits None and What to Do About It

Author: Amy

Institution: Hollow House Institute

Date: May 2026

Category: Policy Whitepaper

Distribution: Zenodo | GitHub | LinkedIn

DOI: 10.5281/zenodo.XXXXXXX [placeholder — to be assigned on deposit]

Cite as: Amy (2026). Sector-Specific AI Governance Kits: Why One Size Fits None and What to Do About It. Hollow House Institute.

Abstract

General-purpose AI governance frameworks — including the NIST AI Risk Management Framework and ISO/IEC 42001 — were designed to be sector-agnostic, and that design choice is simultaneously their greatest strength and their most consequential limitation. Organizations across healthcare, financial services, critical infrastructure, and education are implementing these frameworks in good faith and arriving at governance programs that are technically compliant but substantively thin: programs that do not address the failure modes most likely to cause harm in their specific context, that do not interface coherently with the sector regulation already governing their operations, and that leave the accountability chains unique to their industries unmapped. This paper argues that the solution is not to abandon general frameworks but to build on top of them — through sector-specific governance kits that function as modular overlays, filling the gaps that no universal framework can fill. The paper analyzes four sectors in depth, identifies the structural reasons why sector-specificity is a logical necessity rather than a regulatory preference, defines what a governance kit must contain to be operationally useful, and closes with targeted recommendations for sector regulators, standards bodies, industry consortia, and framework developers. The central claim is simple: AI systems fail in specific contexts, and governance calibrated to that specificity is more effective governance, not more complex governance.

Table of Contents

1. The Misfit Problem: When the Governance Kit Is the Wrong Size

2. Why Generic Frameworks Miss the Point: A Structural Argument

2.1 Failure Modes Are Sector-Specific

2.2 Existing Sector Regulation Creates an Overlay

2.3 The Accountability Chain Differs by Sector

3. Four Sectors in Depth

3.1 Healthcare AI

3.2 Financial Services AI

3.3 Critical Infrastructure AI

3.4 Education AI

4. What a Governance Kit Actually Contains

5. Who Builds Sector Kits and How

6. Sector Governance Kit Summary: General Frameworks vs. Kit Additions

7. Recommendations

8. Conclusion

9. References

1. The Misfit Problem: When the Governance Kit Is the Wrong Size

Picture a large regional hospital system — six facilities, three hundred beds apiece, a mixed urban and suburban patient population with the demographic complexity that implies. Over the past two years, the system has deployed seven AI tools across clinical and administrative functions: a sepsis prediction model, a radiology assistance tool, a patient deterioration alert system, an automated prior authorization classifier, a no-show prediction model, a clinical documentation assistant, and a medication reconciliation tool. The governance lead, a former quality improvement director who has spent the past eighteen months building what she believes is a serious AI governance program, walks into a board risk committee meeting and presents the fruits of that effort. The system has completed the GOVERN function of the NIST

AI Risk Management Framework. They have established an AI risk register. They have documented their systems according to the MAP function. They have standing monitoring processes in place. The board asks four questions.

What is the hospital's clinical liability exposure when the sepsis prediction model produces a false negative that contributes to a patient death? The governance lead cannot answer, because the NIST AI RMF does not address clinical liability. What are the regulatory consequences under the FDA's Software as a Medical Device framework if the radiology assistance tool is modified by the vendor without a new premarket submission? She cannot answer, because the NIST AI RMF does not interface with FDA regulatory pathways. What does the hospital's credentialing and peer review process require when an AI-assisted clinical decision is implicated in an adverse patient outcome? She cannot answer, because the NIST AI RMF was not designed for organizations that have credentialing and peer review processes. Who, in the clinical governance structure, owns the AI risk? The Chief Medical Officer? The Chief Information Officer? The department chair of whichever specialty used the tool? She cannot answer cleanly, because the NIST AI RMF describes accountability in terms of developers and deployers — categories that map awkwardly onto a hospital system governed by a medical staff with independent credentialing authority and a board with fiduciary duties over patient safety.

The NIST AI Risk Management Framework is, in every meaningful sense, a serious and thoughtful document. It represents years of multi-stakeholder collaboration and reflects genuine sophistication about AI risk. We do not cite it to criticize it. We cite it because its authors explicitly describe it as "voluntary, rights-preserving, non-sector-specific, and use-case agnostic," and they are right — that is exactly what it is. The problem is not that the NIST AI RMF is a bad framework. The problem is that "non-sector-specific and use-case agnostic" is a description of what the framework deliberately chose not to be, and organizations are using it as though that choice doesn't matter. It matters enormously. The governance kit was the wrong size for the hospital — not because the kit was poorly made, but because it was made to fit everyone, which is another way of saying it was made to fit no one exactly.

This is not a problem unique to hospitals, or to the NIST AI RMF, or to any particular framework. ISO/IEC 42001:2023, the first international AI management system standard, is explicitly designed for "entities providing or utilizing AI-based products or services" and is intentionally cross-sectoral in scope. The EU AI Act, the most ambitious binding AI regulatory instrument currently in force, establishes risk categories and conformity assessment requirements that apply across sectors with only partial carve-outs for specific contexts. Each of these instruments was developed under the reasonable political and practical logic that a governance framework covering all sectors is more achievable, more durable, and less prone to regulatory fragmentation than a family of sector-specific regimes developed in parallel. That logic is not wrong. But it produces a result that organizations implementing the frameworks discover, often painfully, in practice: the generic framework handles the generic risks well and the sector-specific risks not at all. The specific risks — the ones calibrated to the particular failure modes, the particular regulatory context, the particular accountability structures, and the particular affected populations of a given sector — go ungoverned. Organizations achieve compliance with the framework and leave the actual problem unaddressed.

We call this compliance theater: the performance of governance without the substance of it. It is not the result of bad faith. It is the predictable outcome of applying the wrong tool to the job. This paper is about building the right tools — not to replace the general frameworks, but to complete them.

2. Why Generic Frameworks Miss the Point: A Structural Argument

Before describing what sector-specific governance kits should contain, it is worth being precise about why the gap exists. This is not simply a matter of frameworks needing more detail, or organizations needing more guidance on implementation. The gap between generic AI governance frameworks and the governance needs of specific sectors is structural. It arises from three features of how sectors differ from one another that no single cross-sector framework can fully account for.

2.1 Failure Modes Are Sector-Specific

Consider what it means for an AI system to produce an incorrect output. In a credit underwriting context, a false positive — a creditworthy applicant incorrectly denied — is a harm to an individual that is significant but potentially reversible: the applicant can seek recourse, reapply, find another lender. In a clinical triage context, a false negative — a patient incorrectly assessed as low-acuity — can contribute directly to irreversible patient harm or death. In a high-frequency trading context, a systematically erroneous model can trigger a cascade of correlated sell orders that destabilizes a market in minutes. In a grid management context, an AI system operating under adversarial manipulation might trigger load imbalances with physical consequences for infrastructure and the populations that depend on it. These are not variations on the same risk. They are categorically different failure modes, with different affected populations, different harm timelines, different reversibility, and different appropriate responses.

A governance framework that categorizes all of these under a generic heading like "incorrect output" or "performance degradation" is not equipped to govern any of them well. The risk category is accurate — the outputs are indeed incorrect — but the category lacks the resolution necessary to drive the governance response appropriate to the context. It is the difference between a diagnosis of "pain" and a diagnosis that distinguishes between a sprained ankle and a pulmonary embolism. Both are correct. Only one is useful. Generic frameworks necessarily operate at the "pain" level because they must be applicable to all contexts simultaneously. Sector kits exist to provide the diagnostic specificity that general frameworks, by design, cannot.

2.2 Existing Sector Regulation Creates an Overlay

Almost every consequential sector in the economy already operates inside a dense regulatory framework that predates AI governance as a policy domain. Healthcare AI operates inside FDA regulation of software as a medical device, CMS coverage and reimbursement requirements, Joint Commission accreditation standards, HIPAA data privacy requirements, and the clinical

liability law of whichever jurisdiction the system operates in. Financial services AI operates inside Federal Reserve model risk management expectations codified in SR 11-7, SEC and CFTC market oversight, ECOA and fair lending law, Basel III capital requirements, and MiFID II algorithmic trading rules. Critical infrastructure AI operates inside CISA and sector-specific regulatory frameworks for energy, aviation, nuclear, and transportation. Education AI operates inside FERPA, COPPA, and an emerging patchwork of state-level student privacy law.

None of these sectoral regulatory frameworks were designed for AI governance specifically, but all of them create legally binding obligations that apply to AI systems used in their sectors. An AI governance program that does not explicitly interface with these obligations does not produce compliance clarity — it produces compliance confusion, because organizations are left to determine for themselves how their AI governance commitments relate to their sector regulatory obligations, and the relationships are neither obvious nor always consistent. Worse, organizations may satisfy the requirements of their general AI governance framework while leaving a material sector regulatory obligation unaddressed, creating legal exposure they cannot see because their governance program's field of vision does not extend to sector law. General frameworks cannot solve this problem because they cannot anticipate the specific intersection of AI governance and sector regulation across every sector. Sector kits can, because they are built precisely for that intersection.

2.3 The Accountability Chain Differs by Sector

Perhaps the most consequential structural gap is in accountability. Generic AI governance frameworks describe responsibility in terms that make sense at the level of abstraction they operate at: developers design systems, deployers operate them, and governance obligations attach to these roles. This is a reasonable first approximation. But when you drop it into a specific sector, the first approximation breaks down quickly. In healthcare, the accountability chain runs through licensed clinical practitioners who bear individual professional liability for patient care decisions, even — and this is the crucial and currently unresolved question — when those decisions are informed by AI recommendations they cannot fully evaluate. The chain then extends through hospital systems with institutional liability, through credentialing bodies that set standards for who may practice and under what conditions, through professional liability insurers who price the risk, and through the FDA and CMS as regulators of both the technology and the reimbursement environment. The categories "developer" and "deployer" exist somewhere in this chain, but they do not exhaust it and they are not the primary accountability-bearing nodes.

In financial services, the accountability chain runs through regulated entities — banks, broker-dealers, investment advisers — that bear fiduciary duties to clients and capital adequacy obligations to regulators. Model risk, in the Federal Reserve's framework, is ultimately an institutional responsibility of the bank deploying the model, not a shared responsibility with the vendor who built it. In critical infrastructure, accountability runs through government-designated operators who carry national security obligations that have no direct analog in generic AI governance frameworks. Each of these accountability structures requires governance that names the right parties, assigns responsibility in ways that are legally meaningful within the sector's framework, and creates monitoring processes calibrated to the ways accountability

actually flows. Generic frameworks cannot do this for any specific sector. They describe the structure of accountability at a level of generality that must be operationalized differently in each context, and that operationalization work is precisely what a sector kit exists to do.

► Definition: Compliance Theater

Compliance theater refers to the condition in which an organization satisfies the documented requirements of an AI governance framework while leaving the substantive risks specific to its operating context ungoverned. It is the predictable result of applying a general-purpose framework to a sector-specific context without adaptation. The organization can demonstrate conformance; it cannot demonstrate effective risk management. The distinction matters because auditors assess the former and patients, clients, and the public experience the latter.

3. Four Sectors in Depth

The following four sector analyses do not exhaust the universe of contexts where sector-specific governance kits are needed — a case could be made for criminal justice, immigration, social benefits administration, and others. We focus on these four because they represent a useful range of failure mode types, regulatory environments, accountability structures, and affected populations, and because the governance gaps in each are sufficiently well-documented to be analyzed with specificity rather than generality.

3.1 Healthcare AI

Healthcare AI is probably the most intensively discussed sector from an AI governance perspective, and yet it remains among the most poorly governed in practice. The discussion, ironically, may be part of the problem: years of high-level policy attention have produced a great deal of principle-setting and very little operationally specific governance architecture. The gap between what healthcare organizations are told they should do and what they actually have the governance infrastructure to do is wide, and it widens further the more clinically consequential the AI system in question.

The specific failure modes of healthcare AI do not reduce to a single category. Diagnostic AI — systems that assist in reading imaging, pathology slides, or ECG traces — can fail through systematic underperformance on particular demographic groups, through distribution shift as the patient population or imaging equipment changes over time, or through over-reliance by clinicians who reduce their own independent judgment as confidence in the system grows. Triage and deterioration prediction models can fail through miscalibration that produces alert fatigue — the clinical equivalent of a car alarm so frequently wrong that it is ignored when it matters. Treatment recommendation systems can fail through training data that reflects historical patterns of care that were themselves biased or substandard. Population health models can fail through slow drift that is invisible until it has produced a significant, measurable disparity in outcomes. Billing and documentation AI can fail in ways that expose organizations to

fraud liability, not because the system was designed to defraud but because it learns to optimize for billing codes in ways that do not accurately reflect clinical reality.

Each of these failure modes has different governance implications, and a governance program that addresses only "AI performance" as a generic category will miss most of them. The sepsis prediction model that was validated on the hospital's own historical data has a performance monitoring problem that is fundamentally different from the radiology assistance tool that was validated by its manufacturer on a demographically unrepresentative training set. Treating them identically — as two instances of the same governance problem — produces a governance program that addresses neither well.

The regulatory interface for healthcare AI is unusually complex, even by the standards of heavily regulated sectors. The FDA's regulatory authority over Software as a Medical Device was significantly clarified by the 21st Century Cures Act and subsequent guidance, and the agency's December 2024 final guidance on Predetermined Change Control Plans for AI-enabled devices represents a genuine attempt to create a regulatory pathway that accommodates the iterative, adaptive character of AI systems while preserving the agency's ability to ensure safety and effectiveness. Under the PCCP framework, manufacturers of AI-enabled devices can include in their marketing submissions a plan for future modifications that, if implemented within the plan's specifications, will not require new premarket submissions. This is a meaningful governance mechanism for adaptive AI, but it creates significant governance obligations for deploying organizations: they must track which version of an AI device they are operating, whether that version was modified within a cleared PCCP or requires a new submission, and what their own monitoring obligations are as deployers of an FDA-regulated device.

None of this appears in general AI governance frameworks, because none of it is generalizable across sectors. And yet a hospital operating a radiology AI tool is legally obligated to navigate it correctly. The Joint Commission's standards for clinical decision support add another layer, establishing requirements for the oversight of CDS tools that are operationally specific to accredited healthcare organizations. CMS creates yet another layer through its coverage and reimbursement policies, which increasingly affect which AI-assisted services are billable and under what conditions. The result is an organization that faces AI-related regulatory obligations from at least three distinct federal frameworks — FDA, CMS, and HIPAA — plus Joint Commission accreditation requirements and state clinical liability law, and that must integrate all of these with whatever general AI governance framework it has adopted. Without explicit sector-kit guidance on how these obligations relate to each other, organizations manage each regulatory relationship independently and in silos, which produces duplication in some areas and dangerous gaps in others.

The accountability problem in healthcare AI is particularly acute because it sits at the intersection of unsettled law and rapidly evolving technology. The Lancet and other clinical journals have argued — correctly, in our view — that institutional liability structures must redistribute responsibility from individual clinicians to the organizations that deploy AI systems and the developers that build them. The argument is straightforward: a radiologist who relies on an AI tool that was validated, cleared by the FDA, and implemented by the hospital's IT

department cannot, in any meaningful sense, bear individual professional liability for the tool's error if the error was in a dimension the radiologist had no means to evaluate. But current law in most US jurisdictions has not caught up with this argument, and the practical result is that clinicians carry professional liability for decisions they make with AI assistance while having no meaningful visibility into the AI system's limitations, training data characteristics, or demographic performance gaps.

A governance kit for healthcare AI must address this accountability gap directly, even in the absence of legal resolution, by establishing explicit institutional responsibility for AI performance monitoring, requiring that clinicians be provided with the information they need to appropriately calibrate their reliance on AI recommendations, and creating documented escalation pathways when AI-related adverse events occur. It must also include the equity monitoring that generic frameworks omit. Research published in *Nature* has documented that chest X-ray classifiers trained on historical data systematically underdiagnose Black patients, with false negative rate disparities as large as 30% across age groups in some tasks. Healthcare AI used in clinical settings must be monitored not only for overall performance but for performance disaggregated by the demographic characteristics known to be associated with historical disparities — race, ethnicity, sex, age, socioeconomic status, and language. This is not an aspirational principle; it is a minimum operational requirement for any healthcare organization that takes its health equity obligations seriously.

► Key Finding: The Healthcare Accountability Gap

In most US jurisdictions, individual clinicians bear professional liability for AI-assisted clinical decisions even when they have no meaningful access to information about the AI system's failure modes, demographic performance gaps, or regulatory status. This accountability structure is not merely unfair to clinicians — it is also ineffective as a governance mechanism, because it places liability at a point in the chain that has the least ability to prevent or detect AI failures. A healthcare governance kit must explicitly redistribute institutional accountability and create the information infrastructure that makes distributed accountability meaningful.

The kit elements specific to healthcare AI should therefore include: clinical validation requirements that go beyond technical performance benchmarks to include demographic performance disaggregation and prospective clinical validation in the deployment population; peer review integration that specifies how AI-related adverse events are reviewed within existing medical staff review processes; adverse event reporting requirements that tie AI-related events to the hospital's existing clinical incident reporting infrastructure and, where applicable, to FDA's mandatory device reporting requirements; patient disclosure requirements that specify when and how patients are informed that AI is being used in their care; and explicit mapping of the hospital's AI governance obligations to its FDA regulatory obligations under the PCCP framework, to its Joint Commission accreditation requirements, and to its CMS reimbursement conditions.

3.2 Financial Services AI

Financial services has the distinction of being the only sector with something that already functions, partially, as a sector-specific AI governance document. The Federal Reserve's 2011 Supervisory Guidance on Model Risk Management — SR 11-7 — is not an AI governance framework in the contemporary sense of that term, but it is the most operationally specific model governance document that any major regulatory body has produced for any sector, and the fact that it was written fifteen years ago only underscores how thoroughly the financial sector has thought about model risk relative to most other sectors. SR 11-7 establishes requirements for model development, validation, implementation, and ongoing monitoring that are specific, auditable, and — critically — enforced through the supervisory examination process in ways that general AI governance frameworks are not. When we describe what sector-specific governance kits should aspire to, SR 11-7 is the closest existing exemplar, despite its age and its origin in a pre-deep-learning world.

The specific failure modes of financial services AI are well enough documented to be named precisely. Credit scoring and underwriting AI can produce discriminatory outcomes that violate ECOA and the Fair Housing Act, either through direct use of prohibited characteristics or through the use of proxy variables that correlate strongly with protected class membership. This is not a hypothetical risk: federal enforcement actions and academic research have both documented the phenomenon in deployed consumer lending systems. Algorithmic trading systems can contribute to market instability through correlated behavior at speeds that make human intervention practically impossible — the Nikkei's single-day 12.4% drop in August 2024, the largest since Black Monday in 1987, accelerated significantly through algorithmic cascade as automated systems responded to price signals without any capacity to distinguish the underlying cause of the movement. The IMF's October 2024 Global Financial Stability Report identified AI-driven market convergence — the tendency of AI-powered trading strategies trained on the same data to respond to stress scenarios in similar ways, simultaneously withdrawing liquidity when it is most needed — as a medium-term systemic risk that existing regulatory frameworks do not adequately address.

Model risk in systemically important financial institutions presents governance challenges that are qualitatively different from model risk in smaller institutions. A model used by a large bank to price derivatives contracts, manage capital requirements, or conduct stress testing has potential market-wide exposure that creates governance obligations not just to the institution's own stakeholders but to the financial system as a whole. The failure of a single widely-adopted model — as demonstrated by the 2007 "Quant Quake," in which correlated deleveraging by quantitative funds produced a market dislocation that significantly exceeded what the models themselves predicted — is not an institutional risk; it is a systemic one. Insurance AI adds another dimension: AI-based risk classification in insurance markets can produce discriminatory outcomes that parallel the fair lending problem in credit, but the regulatory framework for insurance discrimination is fragmented across state regulators without a federal equivalent of ECOA, creating enforcement gaps that governance kits must acknowledge and address.

The speed problem in financial services AI deserves separate treatment because it creates a governance challenge with no clear parallel in other sectors. High-frequency trading systems operate at microsecond timescales. Algorithmic market-making systems adjust quotes thousands of times per second. Automated portfolio rebalancing systems can execute large

position changes in response to market signals before any human being can evaluate whether those signals justify the response. Governance frameworks that assume human oversight as a meaningful check on automated decision-making are simply wrong about how high-frequency financial AI operates. The realistic question for governance in these contexts is not "how do we ensure humans review AI decisions before they are executed" — that ship has sailed, and the liquidity benefits of algorithmic market-making are deeply embedded in current market structure. The realistic question is "what pre-deployment validation, parameter constraints, circuit-breaker requirements, and post-execution monitoring processes are appropriate given that human real-time oversight is not feasible." A governance kit for high-frequency trading AI must be built around this realistic question. A governance kit for credit underwriting AI — where the timescales are weeks and human review is both feasible and legally required in many contexts — must be built around a different set of questions entirely. The difference within a single sector is significant enough that financial services governance kits may need to be sub-segmented by application type.

Kit elements specific to financial services should include: model risk management integration that explicitly maps general AI governance requirements onto SR 11-7's development, validation, and use cycle, ensuring that organizations do not run parallel and potentially inconsistent governance processes; explainability requirements calibrated to the adverse action notice obligations under Regulation B and CFPB Circular 2022-03, which requires that AI-generated credit denials be accompanied by specific, accurate reasons rather than generic model output flags; stress testing requirements for AI models with material exposure to market or credit risk; and systemic risk monitoring requirements for models whose widespread adoption creates concentration risk at the market level. The CFPB's 2022 circular is worth noting as a concrete example of where sector-specific AI governance requirements have already outpaced general framework guidance: it addresses a specific problem — the inability of black-box AI models to generate the specific adverse action reasons that Regulation B requires — that no general AI governance framework has addressed with equivalent specificity.

3.3 Critical Infrastructure AI

Critical infrastructure AI presents governance challenges that are structurally unlike those in other sectors, and the difference is not one of degree but of kind. In healthcare, the primary risk is harm to individual patients through incorrect recommendations. In financial services, the primary risk is harm to individual consumers through discriminatory decisions, or systemic harm through model-driven instability. In critical infrastructure, the primary risk category is physical harm to populations at scale — power outages affecting millions, transportation system failures with direct safety consequences, water treatment disruptions that create public health emergencies — potentially combined with adversarial intent to cause exactly those outcomes. The governance problem is not, primarily, about managing the risk of an AI system getting things wrong in a benign environment. It is about managing the risk of AI systems that operate at the intersection of physical safety, national security, and active adversarial threat.

The specific failure modes reflect this character. Cascading failure is the most distinctive: in tightly coupled infrastructure systems, a localized AI-driven error can propagate through

physical and computational dependencies in ways that produce system-wide outcomes far exceeding the initial failure. The 2003 Northeast blackout — which preceded AI deployment in grid management — demonstrated how a single initiating failure in an automated monitoring system could cascade, through a sequence of automated and human responses, into an outage affecting 55 million people across eight US states and Canada. AI-driven infrastructure management increases both the efficiency potential and the cascade risk of these systems simultaneously. Adversarial manipulation is a failure mode that generic AI governance frameworks treat as an edge case or an advanced topic. For critical infrastructure AI, it is a primary design constraint. A power grid management AI that can be destabilized by spoofed sensor data, a water treatment system that can be manipulated through adversarial inputs to AI-driven chemical dosing, or an aviation traffic management system that can be confused through GPS spoofing represents an attack surface that is qualitatively different from the misuse risks that general frameworks contemplate.

The regulatory landscape for critical infrastructure AI is fragmented in ways that create genuine governance confusion for operators. CISA has been the most active federal body in developing AI-specific guidance for critical infrastructure, and its December 2025 joint publication with the Australian Cyber Security Centre and international partners — *Principles for the Secure Integration of Artificial Intelligence in Operational Technology* — represents the most operationally detailed guidance currently available for AI in OT environments. The guidance's four principles — understand AI, assess AI in OT, establish AI governance, and embed safety and security — are well-grounded, but they remain at a level of generality that requires significant sector-specific adaptation for energy (NERC CIP), aviation (FAA oversight), nuclear (NRC regulations), or transportation (TSA requirements). NERC CIP, the reliability standard for the bulk electric system, has not yet been updated to address AI-specific risks in grid management AI. The FAA's approach to AI in air traffic management is still evolving. The result is that critical infrastructure operators face a CISA-level framework that is genuinely useful but sector-incomplete, and sector-specific regulatory frameworks that govern their operations but have not yet developed AI-specific requirements at the operational level.

The adversarial threat model is worth dwelling on because it has such direct implications for governance kit design. Generic AI governance frameworks discuss adversarial robustness as one consideration among several. For critical infrastructure AI, it is the consideration that shapes everything else. Red-teaming requirements — systematic attempts to find exploitable vulnerabilities in AI systems before deployment — are not optional enhancements for infrastructure AI; they are minimum requirements. Adversarial robustness standards, currently underdeveloped even in the most advanced AI governance literature, must be specified at the level of realistic threat actors and attack vectors for the specific infrastructure sector in question. The threat model for an energy grid management AI is different from the threat model for a port logistics AI, which is different from the threat model for an aviation management AI. Generic guidance cannot capture these differences. Sector kits must.

Kit elements specific to critical infrastructure AI include: safety-critical design requirements that mandate fail-safe behavior — defined, tested, predictable system behavior under failure conditions — rather than best-effort performance; human override requirements with specified response time guarantees and regular testing; adversarial testing protocols calibrated to the

specific threat model of the relevant infrastructure sector, including both automated and human red-teaming; failure mode and effect analysis requirements specific to the infrastructure context; and explicit coordination requirements with CISA and sector-specific regulators that formalize the relationship between the organization's AI governance program and its existing regulatory compliance obligations. The governance kit should also address the specific challenge of AI in operational technology environments where software update cycles are long, redundancy requirements are high, and the tolerance for system changes is low — constraints that significantly affect what governance mechanisms are feasible and how they must be designed.

3.4 Education AI

Education AI occupies a distinctive position in the governance landscape for reasons that have as much to do with the nature of the affected population as with the specific AI applications involved. Students — particularly K-12 students — are a uniquely vulnerable population for AI governance purposes: they are minors who cannot meaningfully consent to AI-mediated decisions about their educational trajectories, they interact with AI systems in contexts controlled by institutions they are legally required to attend, and the decisions those systems shape — about ability grouping, course placement, disciplinary action, college counseling — can have compounding effects on life outcomes that are difficult to reverse. These characteristics create governance obligations that are qualitatively different from those arising in sectors where affected individuals are adults with alternative options and meaningful recourse.

The failure modes of education AI reflect this character. Algorithmic sorting — the use of AI to group students by inferred ability, predict college readiness, or recommend course tracks — can entrench and accelerate existing educational inequalities by encoding historical patterns of opportunity into predictions about future potential. A college readiness prediction model trained on historical data from a school district with documented resource inequalities will, unless actively corrected for, systematically underpredict the potential of students from underserved communities, producing recommendations that foreclose opportunities rather than expand them. Surveillance overreach is a second significant failure mode: the pandemic-era acceleration of AI-based proctoring, behavior monitoring, and attendance tracking tools deployed in educational settings has produced documented harms including false flagging of students with disabilities, discriminatory error rates across demographic groups, and significant chilling effects on student behavior that educational researchers have characterized as pedagogically harmful. The data protection risks for minors are severe and underappreciated: the combination of FERPA's broad definition of education records, COPPA's requirements for commercial operators engaging with children under 13, and the general consumer AI ecosystem's data practices creates a regulatory surface of considerable complexity for any educational AI deployment.

The power imbalance problem in education is fundamental and is not adequately addressed by any existing AI governance framework. When a general AI governance framework discusses transparency and explainability requirements, it typically contemplates an affected individual who can receive an explanation and, if they find it insufficient, seek recourse. This model has limited applicability to a seventh-grader whose school district has deployed an AI system that informs the teacher's assessment of her learning needs, because the seventh-grader cannot

negotiate with the school district, cannot opt out of attending school, and may not even know that an AI system has informed how she is being taught. The transparency requirements that make sense for adult consumers in financial or healthcare contexts must be significantly redesigned for educational contexts to account for this power asymmetry — and the redesign is not a minor adjustment. It requires rethinking who receives the explanation (parents, school counselors, the student at age-appropriate level), what the explanation must contain, and what rights of contestation attach to it.

The regulatory landscape for education AI in the United States is thin by the standards of other sectors. FERPA provides important data privacy protections but was not designed for AI governance and does not directly address automated decision-making. COPPA limits commercial data collection from children under 13 but leaves significant gaps for educational technology deployed in school settings. The US Department of Education has no equivalent of the FDA's SaMD guidance or the Federal Reserve's SR 11-7 — no operationally specific framework for AI governance in educational settings that carries regulatory force. The state-level landscape is evolving rapidly: according to recent reporting, approximately twenty states now reference AI-specific requirements in education procurement guidance, and several — including California, Ohio, and Vermont — have published substantive AI governance frameworks for K-12 settings. But state-level fragmentation creates compliance burden for educational technology vendors and governance confusion for districts operating across state lines. The EU's GDPR Article 22 prohibition on automated decision-making with significant effects, which extends to AI decisions affecting minors, provides stronger baseline protections for European students than any US federal framework, and the gap is relevant context for any discussion of what a US education AI governance kit needs to supply.

The evidence problem in education AI is perhaps the governance issue most distinctive to this sector. Educational technology has a long history of tools deployed at scale based on vendor-supplied claims about learning outcomes that have not been independently validated. The AI era has accelerated this pattern: AI tutoring tools, adaptive learning platforms, and writing assistance systems are being adopted at significant scale based on efficacy claims that often rest on internal pilot studies, user satisfaction surveys, or performance on proxy metrics that do not translate reliably to learning outcomes. A governance kit for education AI must include evidence requirements for efficacy claims — not as an aspirational standard but as a procurement condition — because deploying an educational AI tool without evidence of efficacy is itself a form of harm to students, even if the tool does not actively discriminate or surveil. Students spend time with these tools that could be spent on approaches with documented efficacy. In a sector where instructional time is a finite and precious resource, that is a governance-relevant cost.

Kit elements specific to education AI include: robust data minimization requirements that specify what student data AI systems may collect, process, and retain, calibrated to FERPA and COPPA obligations; categorical prohibitions on certain application types that present governance risks disproportionate to educational benefit — behavioral prediction systems, emotion recognition tools, and surveillance AI used for disciplinary purposes; mandatory human review requirements for any AI-informed decision with significant consequences for student placement, discipline, or opportunity; evidence standards for efficacy claims that require

independent validation before large-scale deployment; and specific transparency and notice requirements addressed to parents and age-appropriate students that explain what AI is in use, what decisions it informs, and how those decisions can be reviewed or contested.

► **Critical Finding: The Evidence Gap in Education AI**

Many educational AI tools are currently deployed at scale on the basis of efficacy claims that have not been independently validated. Generic AI governance frameworks address performance monitoring for deployed systems but do not address the pre-deployment evidence question: whether the tool does what it claims to do for the student population that will use it. For a sector where instructional time is finite and irreplaceable, deploying an AI tool without evidence of efficacy is a governance failure regardless of whether the tool produces discriminatory outcomes or privacy violations. Education sector governance kits must establish minimum evidence standards as a condition of procurement, not merely as a post-deployment evaluation criterion.

4. What a Governance Kit Actually Contains

Having established the case for sector specificity and worked through what it implies in four concrete contexts, we can now define the concept of a governance kit with the precision it requires. A sector-specific governance kit is not a separate regulatory regime. It is not a replacement for the NIST AI RMF or ISO 42001 or the EU AI Act. It is a structured, modular overlay document — designed to be used by organizations that have already adopted a general framework — that supplies the sector-specific content that general frameworks cannot provide. It is, to use an architectural metaphor, the fit-out rather than the structure: general frameworks provide the load-bearing walls; the governance kit provides everything needed to make the space functional for its specific intended purpose.

A well-designed governance kit has six distinct components, each of which serves a function that the general framework it overlays cannot perform. The first is a sector failure mode map: a structured analysis of the AI failure modes most likely to cause harm in the specific sector, organized by application type and linked to the risk categories in the relevant general frameworks. This map does not replace the general framework's risk taxonomy; it populates it with sector-specific content that makes the taxonomy actionable. An organization using the NIST AI RMF's MAP function with access to a healthcare sector failure mode map knows what it is mapping for, rather than applying the framework's generic risk categories to a healthcare context and hoping the translation works.

The second component is a regulatory interface guide: a document that identifies the specific sector regulations that apply to AI systems in the sector, explains what those regulations require at the operational level, and maps the obligations they create onto the relevant elements of the general AI governance framework. For healthcare, this means explicitly connecting FDA PCCP obligations, Joint Commission clinical decision support standards, CMS conditions of participation, and HIPAA requirements to the GOVERN, MAP, MEASURE, and MANAGE functions of the AI RMF. The regulatory interface guide does not interpret sector law —

organizations need legal counsel for that — but it identifies the connections that organizations need to think through and provides a starting point for the analysis.

The third component is a sector-calibrated accountability chain: a specification of who is accountable for what in the sector's AI governance structure, written in the language of the sector's existing accountability framework rather than the generic language of "developers" and "deployers." In healthcare, this means specifying the respective accountability roles of the health system's board, the CMO, the AI governance committee (if one exists), clinical department chairs, individual clinicians, the AI vendor, and the relevant regulators. In financial services, it means specifying the respective roles of the board risk committee, the Chief Risk Officer, model risk management function, the line of business deploying the model, the vendor, and the relevant regulators. These specifications can be adapted to the specific organizational structure of the implementing organization, but the kit provides the sector-specific template.

The fourth component is a set of sector-specific evaluation criteria: the performance benchmarks, equity metrics, robustness tests, and monitoring requirements that are specific to the sector and that the general framework does not specify. For healthcare, this includes demographic performance disaggregation requirements. For financial services, it includes stress testing requirements and fair lending testing methodologies. For critical infrastructure, it includes adversarial robustness requirements and fail-safe specifications. For education, it includes evidence standards for efficacy claims. These are not optional enhancements; they are the minimum requirements for governance to be meaningful in the sector context.

The fifth component is a sector-specific monitoring and incident response template: a document that specifies how AI-related incidents are identified, escalated, investigated, and reported in the sector, using the sector's existing incident management infrastructure as the basis. For healthcare, this means tying AI incident response to the existing clinical incident reporting process and, where applicable, to FDA medical device reporting requirements. For financial services, it means specifying how AI-related model failures are escalated through the model risk management process and reported to relevant regulators. The kit provides the template; the implementing organization populates it with its own process specifics.

The sixth component is a sector-specific communications and disclosure guide: specifications for what affected individuals — patients, borrowers, students, the public — must be told about AI systems that affect them, in what form, and with what recourse options. This is the component that most directly addresses the accountability asymmetries that generic frameworks leave unresolved.

5. Who Builds Sector Kits and How

The question of who builds sector governance kits is not merely logistical; it is a governance question in its own right, because the legitimacy and uptake of a sector kit depends substantially on the process through which it was developed. A kit developed by an industry association without meaningful input from affected communities, sector regulators, or independent researchers will produce a document optimized for industry convenience rather than effective

risk management. A kit developed by a regulator without meaningful industry input will produce requirements that are technically sound but operationally impractical. The most effective sector kits will be developed through multi-stakeholder processes that bring together sector regulators, industry practitioners, affected communities, independent researchers, and AI governance specialists — not in the sense of a formal advisory committee with a year-long calendar and a report that nobody reads, but in the sense of a structured collaborative process grounded in actual failure case analysis, operational specificity, and genuine willingness to reach disagreement rather than paper it over with principle-level consensus.

The FDA's approach to SaMD guidance development is an instructive positive example. The agency's multi-year process for developing the action plan, draft guidance, and ultimately the 2024 final guidance on PCCPs for AI-enabled devices involved extensive public comment, bilateral engagement with device manufacturers, academic researchers, and patient advocates, and iterative refinement based on real implementation experience. The result is guidance that, while imperfect and still evolving, is operationally specific enough that a device manufacturer can actually use it. The process took years longer than a purely internal development process would have taken. Those years produced a document that the industry trusts enough to act on, which is the point.

SR 11-7 is a different kind of exemplar — one developed through a less public process but with intensive engagement with banking institutions during the supervisory examination process, which provided the Federal Reserve and OCC with ground-level knowledge of how model risk actually manifests in banking practice. The guidance's durability — it has governed model risk management in banking for fifteen years, through the deep learning revolution, through the generative AI surge, and through every intervening AI development cycle — reflects the fact that it was grounded in operational reality rather than theoretical governance principles. Recent FFIEC and OCC guidance has extended SR 11-7 to AI and ML models explicitly without having to rewrite the framework's foundations, which is a meaningful demonstration of what good sector-specific governance architecture looks like when it is done well.

CISA's emerging work on critical infrastructure AI illustrates both the potential and the limitations of the regulator-led approach. The December 2025 joint guidance with international partners represents genuine progress in a governance space that was nearly empty two years ago, and the collaboration with international counterparts adds legitimacy and breadth that purely domestic guidance would lack. But the guidance's four high-level principles require significant sector-specific adaptation for each of the sixteen critical infrastructure sectors, and CISA has not yet produced the sector-specific guidance needed to bridge that gap. The will is evident; the resource constraints are also evident. Sector industry associations — NERC in electricity, IATA in aviation, the Water ISAC in water and wastewater — are the logical candidates to develop sector-specific overlays on the CISA principles, but they will need explicit coordination with sector regulators and, critically, with affected communities who bear the consequences when critical infrastructure fails.

What has not worked — and what sector kit development processes must actively avoid — is the production of high-level principles documents that use the language of governance without providing operational content. The AI governance space is already oversupplied with documents

that identify important values — fairness, transparency, accountability, human oversight — and dramatically undersupplied with documents that specify what those values require in practice, for a specific type of system, in a specific institutional context, subject to a specific regulatory framework. Sector kits exist to address that shortage. A sector kit that reproduces it — that produces a healthcare AI governance kit organized around the principles of fairness and transparency without specifying what demographic performance monitoring looks like, which regulatory pathways apply, and who is accountable within a hospital's governance structure — is not a sector kit. It is another principles document with a sector label attached.

6. Sector Governance Kit Summary: General Frameworks vs. Kit Additions

The table below maps four sectors against the core elements of a governance kit, distinguishing between what general frameworks (NIST AI RMF, ISO 42001, EU AI Act) address, what they address partially, and what a sector-specific kit must supply in full.

Governance Element	Healthcare AI	Financial Services AI	Critical Infrastructure AI	Education AI
Risk taxonomy / failure mode map	<i>General frameworks: generic only. Kit must add: diagnostic error, triage miscalibration, model drift, billing fraud.</i>	<i>General frameworks: generic only. Kit must add: credit discrimination, trading instability, systemic model risk, fair lending violations.</i>	<i>General frameworks: generic only. Kit must add: cascading failure, adversarial manipulation, safety-critical control errors.</i>	<i>General frameworks: generic only. Kit must add: algorithmic sorting, surveillance overreach, data protection failures for minors.</i>
Regulatory interface mapping	<i>Not covered. Kit must map: FDA SaMD/PCCP, CMS conditions, Joint Commission, HIPAA.</i>	<i>Not covered. Kit must map: SR 11-7, ECOA/Reg B, CFPB Circular 2022-03, MiFID II, Basel III.</i>	<i>Not covered. Kit must map: CISA OT guidance, NERC CIP, FAA, NRC, TSA sector requirements.</i>	<i>Not covered. Kit must map: FERPA, COPPA, GDPR Art. 22 (for international operations), state AI education laws.</i>
Accountability chain specification	<i>Partial: developer/deployer only. Kit must add: CMO, clinical dept.</i>	<i>Partial: developer/deployer only. Kit must add: board risk</i>	<i>Partial: developer/deployer only. Kit must add: government-design</i>	<i>Partial: developer/deployer only. Kit must add: school board,</i>

	chairs, medical staff, credentialing bodies.	committee, CRO, model risk management, fiduciary duty holders.	ated operators, CISA coordination, sector regulator roles.	principal, teacher, parent, age-appropriate student rights.
Equity and demographic monitoring	<i>Not specified. Kit must add: mandatory disaggregated performance monitoring by race, sex, age, language.</i>	Partial: fairness mentioned. Kit must add: ECOA disparate impact testing, adverse action reason accuracy.	<i>Not addressed. Kit must add: equitable service continuity monitoring across communities.</i>	<i>Not specified. Kit must add: bias testing in sorting/placement algorithms, data collection equity.</i>
Adversarial robustness / security	Mentioned as advanced topic. Kit must add: clinical environment-specific security requirements.	Mentioned. Kit must add: market manipulation testing, high-frequency environment constraints.	<i>Insufficient. Kit must add: mandatory red-teaming, adversarial testing protocols, threat-model-specific standards.</i>	<i>Not addressed. Kit must add: data security for minors, prohibition on adversarial student profiling.</i>
Human oversight / override requirements	General principle. Kit must add: clinician disclosure requirements, peer review integration for AI-related adverse events.	General principle. Kit must add: human override requirements calibrated by AI application type (HFT vs. credit underwriting).	<i>Inadequate. Kit must add: mandatory human override with specified response time guarantees; regular testing.</i>	<i>Not sector-calibrated. Kit must add: mandatory human review for high-stakes decisions; prohibition on certain automated determinations.</i>
Evidence and validation standards	Technical performance benchmarks only. Kit must add: clinical validation in deployment population; demographic	Model validation per SR 11-7. Kit must add: stress testing, fair lending back-testing, systemic exposure assessment.	Performance testing addressed. Kit must add: safety-critical validation standards; fail-safe specification testing.	<i>Not addressed. Kit must add: independent efficacy validation before large-scale deployment; learning outcome evidence standards.</i>

	performance disaggregation.			
Incident response and reporting	General incident process. Kit must add: tie to clinical incident reporting; FDA mandatory device reporting integration.	General incident process. Kit must add: model failure escalation through model risk management; regulatory notification requirements.	<i>Insufficient for OT context. Kit must add: sector-specific incident categories; CISA and sector regulator notification protocols.</i>	General incident process. Kit must add: FERPA breach notification; parent/student notification for AI-related data incidents.
Affected individual rights and disclosure	Transparency principle only. Kit must add: patient disclosure requirements; right to contest AI-informed clinical decisions.	Transparency principle only. Kit must add: adverse action notices with specific AI-generated reason requirements.	<i>Not applicable in standard form. Kit must add: public disclosure requirements for AI in infrastructure management.</i>	<i>Not sector-calibrated. Kit must add: parent/student notice; age-appropriate explanations; contestation rights for AI-informed decisions.</i>

7. Recommendations

The following recommendations are addressed to specific actors whose decisions determine whether sector-specific AI governance kits get built, and built well. They are offered in the spirit of what is actually achievable rather than what would be ideal in a world with unlimited time and resources.

For sector regulators (FDA, Federal Reserve, CISA, Department of Education, and their counterparts): Develop operationally specific AI governance requirements at the sector level rather than deferring to general frameworks and expecting organizations to figure out the intersection. The FDA's PCCP guidance is the model: it took years, it involved extensive multi-stakeholder engagement, and it produced guidance specific enough that device manufacturers know what it requires. The Federal Reserve's SR 11-7, now fifteen years old, is still the most operational AI governance document in any sector. The lesson of both is that operational specificity requires sustained investment and sector knowledge. Regulators who issue one-page AI guidance documents that tell regulated entities to "consult applicable AI governance frameworks" are not governing; they are delegating governance to organizations that do not have the information or authority to perform it. Where sector-specific AI guidance

does not yet exist — as is largely the case in education — the appropriate response is to build it, not to rely on general frameworks to fill the gap by implication.

For standards bodies (NIST, ISO/IEC, IEEE): Develop sector-specific profiles and annexes for general AI governance frameworks that provide the sector-specific content those frameworks are designed to accommodate but do not supply. The NIST AI RMF's profile mechanism was explicitly designed for sector-specific customization; the investment needed is in developing sector profiles through substantive engagement with sector communities, not just industry consultation. ISO 42001's annex structure provides a similar opportunity. The standards that matter most for day-to-day governance practice are not the top-level frameworks but the implementation guidance documents — the sector-specific playbooks that translate framework principles into operational requirements. Those documents are severely undersupplied relative to the top-level frameworks that reference them.

For industry consortia and sector associations (NERC, IATA, AHA, ABA, and others): Do not wait for regulators to build sector kits on your behalf. The most operationally credible sector governance guidance will come from bodies that combine deep sector knowledge with independence from any single organization's interests. Industry associations are well-positioned to develop this guidance, but only if they are willing to engage genuinely with affected community representatives and independent researchers, and only if they are willing to specify requirements that are operationally burdensome rather than retreating to the comfortable ambiguity of principles. The test of whether a sector kit is genuinely useful is whether it makes compliance harder in the short term by specifying things organizations must actually do. If the first version of your sector kit could be satisfied by any organization that already has an AI governance program, the kit is not adding value.

For general AI governance framework developers: Make the limits of general frameworks explicit rather than implicit. When the NIST AI RMF describes itself as "non-sector-specific and use-case agnostic," that is an accurate and important self-description that should be accompanied by explicit guidance on what organizations must do to address the sector-specific gaps the framework leaves. The AI RMF's profile mechanism is valuable but underspecified; the framework should say more clearly what a sector profile must contain to be adequate, and should actively promote the development of sector profiles through formal partnerships with sector regulators rather than leaving profile development to whoever happens to take up the work. ISO 42001 should similarly make its sector-specific adaptation mechanisms more explicit and should partner actively with sector regulators and industry associations to develop annex content that can be adopted as part of certification processes.

For organizations implementing AI governance programs: Do not mistake compliance with a general framework for adequate AI governance. The governance lead who cannot answer the board's four questions about healthcare AI liability, FDA regulatory status, clinical peer review obligations, and accountability structure is not failing at implementation — she is implementing a framework that was not designed to answer those questions and that is not adequate, on its own, for the context she is operating in. Sector-specific governance supplements are not optional enhancements for organizations with sophisticated programs; they are the minimum requirements for governance to be meaningful. If a sector kit does not yet exist for your sector,

the appropriate response is to help build one — through your sector association, through engagement with sector regulators, through collaboration with peer organizations — rather than to assume the general framework is sufficient.

8. Conclusion

The push for universal AI governance frameworks is understandable, and it has produced genuine value. Common risk taxonomy, shared principles, cross-sector monitoring mechanisms, and baseline standards that any AI system should meet regardless of context — these are real contributions, and we should not romanticize the alternative of a fragmented governance landscape in which every sector invents its own approach from scratch. The goal of this paper has never been to argue against general frameworks. The goal has been to argue that general frameworks are necessary but not sufficient, and that "not sufficient" is a serious problem rather than a minor gap to be addressed by better implementation guidance.

AI systems do not fail universally. They fail in specific contexts, affecting specific people, through specific mechanisms, in ways that are shaped by the particular regulatory environment, institutional structure, affected population, and threat model of the sector where they operate. A sepsis prediction model fails as a medical device with FDA regulatory consequences and clinical liability implications. A credit underwriting model fails as a financial services product with ECOA consequences and adverse action notice implications. A grid management AI fails as critical infrastructure with national security implications and potential physical harm at population scale. An education AI fails as a tool operating on a population of minors who cannot meaningfully contest the decisions it shapes. These are not variations on a theme. They are categorically different governance problems that require categorically different governance responses.

Governance that is calibrated to that specificity is more effective governance, not more complex governance. The complexity already exists in the actual risk landscape. Governance that ignores it does not reduce complexity; it simply shifts the consequences of that complexity onto the patients, borrowers, communities, and students who encounter AI systems operating in gaps that no one with governance authority chose to fill. Sector kits are how you fill those gaps without starting from scratch every time — how you build on what general frameworks have genuinely accomplished while adding the sector-specific content that makes governance meaningful in practice. The frameworks are the starting point. The kits are where the real work happens.

9. References

1. [1] Tabassi, E. (2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. NIST AI 100-1. National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.AI.100-1>

2. [2] ISO/IEC. (2023). *ISO/IEC 42001:2023 — Information Technology: Artificial Intelligence — Management System*. International Organization for Standardization / International Electrotechnical Commission.
3. [3] Food and Drug Administration. (2024, December). *Marketing Submission Recommendations for a Predetermined Change Control Plan for Artificial Intelligence-Enabled Device Software Functions: Guidance for Industry and Food and Drug Administration Staff*. U.S. Department of Health and Human Services. Federal Register Docket No. FDA-2022-D-2628.
4. [4] Board of Governors of the Federal Reserve System & Office of the Comptroller of the Currency. (2011, April). *Supervisory Guidance on Model Risk Management*. SR Letter 11-7 / OCC Bulletin 2011-12.
5. [5] Cybersecurity and Infrastructure Security Agency (CISA) & Australian Signals Directorate's Australian Cyber Security Centre. (2025, December 3). *Principles for the Secure Integration of Artificial Intelligence in Operational Technology*. U.S. Department of Homeland Security.
6. [6] Consumer Financial Protection Bureau. (2022, May 26). *CFPB Circular 2022-03: Adverse Action Notification Requirements in Connection with Credit Decisions Based on Complex Algorithms*. Consumer Financial Protection Bureau.
7. [7] International Monetary Fund. (2024, October). *Global Financial Stability Report, Chapter 3: Artificial Intelligence in Capital Markets*. International Monetary Fund.
8. [8] Food and Drug Administration. (2021, January). *Artificial Intelligence/Machine Learning (AI/ML)-Based Software as a Medical Device (SaMD) Action Plan*. Center for Devices and Radiological Health.
9. [9] Zong, Y., Gu, H., Xu, F., et al. (2023). *The limits of fair medical imaging AI in real-world generalization*. *Nature Medicine*, 29, 2838–2848. <https://doi.org/10.1038/s41591-023-02524-1>
10. [10] Dankwa-Mullan, I., et al. (2023). *Bridging Health Disparities in the Data-Driven World of Artificial Intelligence: A Narrative Review*. *Journal of Racial and Ethnic Health Disparities*. Springer.
11. [11] Obermeyer, Z., Powers, B., Vogeli, C., & Mullainathan, S. (2019). Dissecting racial bias in an algorithm used to manage the health of populations. *Science*, 366(6464), 447–453. <https://doi.org/10.1126/science.aax2342>
12. [12] Char, D. S., Shah, N. H., & Magnus, D. (2018). Implementing machine learning in health care — addressing ethical challenges. *New England Journal of Medicine*, 378(11), 981–983. <https://doi.org/10.1056/NEJMp1714229>
13. [13] Mello, M. M., Guha, N., & Shah, P. (2023). Allocating responsibility for failures of AI-assisted decision making. *The Lancet Digital Health*, 5(1), e9–e10.
14. [14] Federal Deposit Insurance Corporation. (2024). *FIL-13-2024: Interagency Guidance on Third-Party Relationships: Risk Management*. FDIC.
15. [15] European Parliament and Council of the European Union. (2024). *Regulation (EU) 2024/1689 — Artificial Intelligence Act*. Official Journal of the European Union.
16. [16] Sidley Austin LLP. (2024, December). Artificial intelligence in financial markets: Systemic risk and market abuse concerns. *Butterworths Journal of International Banking and Financial Law*.

17. [17] U.S. Department of Education. (2023, May). *Artificial Intelligence and the Future of Teaching and Learning: Insights and Recommendations*. Office of Educational Technology.
18. [18] Federal Trade Commission. (2021). *Complying with COPPA: Frequently Asked Questions*. Federal Trade Commission. (Updated with reference to FTC final rule amendments, 2024.)
19. [19] North American Electric Reliability Corporation. (2024). *Critical Infrastructure Protection (CIP) Reliability Standards*. NERC. CIP-002 through CIP-014 series.
20. [20] Singhal, A. (2026, April 29). Why Trading AI Failed in the August 2024 Flash Crash. *LinkedIn*. Veriprajna.
21. [21] FFIEC. (2024). *Interagency Statement on the Use of Artificial Intelligence by Financial Institutions*. Federal Financial Institutions Examination Council.
22. [22] The Joint Commission. (2024). *Clinical Decision Support — Standards and Certification Requirements*. The Joint Commission.
23. [23] Floridi, L., et al. (2021). An ethical framework for a good AI society: Opportunities, risks, principles, and recommendations. *Minds and Machines*, 28(4), 689–707.
<https://doi.org/10.1007/s11023-018-9482-5>
24. [24] National Security Agency Artificial Intelligence Security Center & CISA. (2024). *AI Red Teaming: Applying Software TEVV for AI Evaluations*. U.S. Department of Defense / DHS.
25. [25] Student Privacy Compass. (2026). *State Student Privacy Laws: AI and EdTech Provisions Survey*. Future of Privacy Forum.

Hollow House Institute | *Sector-Specific AI Governance Kits: Why One Size Fits None and What to Do About It* | Amy, May 2026

This paper is published for open distribution. Please cite using the DOI above when assigned. Correspondence: Hollow House Institute. Distribution permitted under CC BY 4.0.

The views expressed in this paper are those of the author and do not constitute legal advice. Organizations should consult qualified legal counsel on matters of regulatory compliance.